

API Authorization

Backend development study note for document retrieval and grounded question-answering practice.

Authorization

Authorization determines whether an authenticated identity is permitted to perform a requested action on a resource. Authentication asks who the caller is; authorization asks what the caller may do.

Role-based access control

Role-based access control (RBAC) assigns permissions to roles and associates users with roles. For example, an administrator role may manage users while a viewer role may only read records.

Enforcement

Authorization should be enforced on trusted server-side components for every protected operation. Hiding a button in the frontend is not sufficient access control.